Task: VAPT Report
Name: Kavita Prajapati

Executive Summary

This assessment was conducted in a controlled lab environment to identify security vulnerabilities in the target system. Using tools such as Nmap, OpenVAS, and Nikto, multiple vulnerabilities were identified including outdated services, exposed ports, and potential web application flaws.

The findings were analyzed using CVSS scoring to determine their severity and prioritize remediation efforts.

Methodology

The vulnerability assessment followed a structured process consisting of the following phases:

1. Environment setup using virtual machines
2. Vulnerability scanning
3. Web server analysis using Nikto
4. Risk assessment using CVSS scoring
5. Documentation and reporting of findings

The assessment followed a structured approach based on:

- http://www.pentest-standard.org/index.php/Main_Page
- https://owasp.org/www-project-web-security-testing-guide

CVSS Scoring System:

The Common Vulnerability Scoring System (CVSS) provides a standardized method for assessing vulnerability severity. Security analysts often use the CVSS calculator provided by the National Vulnerability Database to determine vulnerability scores.

Score Range	Risk Level
0 – 3.9	**Low**
4 – 6.9	**Medium**
7 – 8.9	**High**
9 – 10	**Critical**

Risk Matrix:

A risk matrix is another method used to prioritize vulnerabilities based on their likelihood and impact. EX:,

Vulnerability	Likelihood	Impact	Risk Level
SQL Injection	High	High	Critical
Cross-Site Scripting	Medium	Medium	Medium
Open Ports	Low	Medium	Low

Information:

Item	Details
Project Title	Vulnerability Assessment of Metasploitable and Kali Linux Environment
Assessment Type	Vulnerability Assessment Lab
Tools Used	Kali Linux, OpenVAS, Nikto, Nmap
Target System	Metasploitable
Testing Environment	VirtualBox Lab
Date	21/03/2026

Executive summary:

The objective of this assessment was to identify security vulnerabilities in a controlled testing environment using open-source security tools. The assessment was performed on a vulnerable virtual machine to simulate a real-world security evaluation scenario.

The scanning process identified several vulnerabilities including outdated software versions, exposed services, and configuration weaknesses. These issues could potentially allow attackers to gain unauthorized access to the system if not properly mitigated. Risk assessment was performed using CVSS scoring to prioritize remediation efforts.

Tools Used:

Tool	Purpose
Kali Linux	Security testing platform
Nmap	Port Scanning
Nikto	Web server security testing
Oracle VM VirtualBox	Virtual lab environment

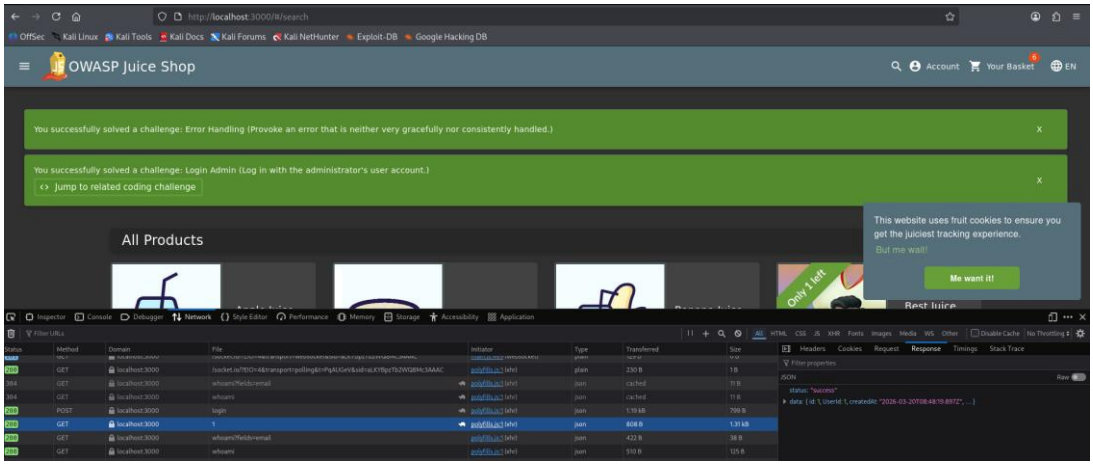
The below table gives a brief description of each risk rating visualized in this report.

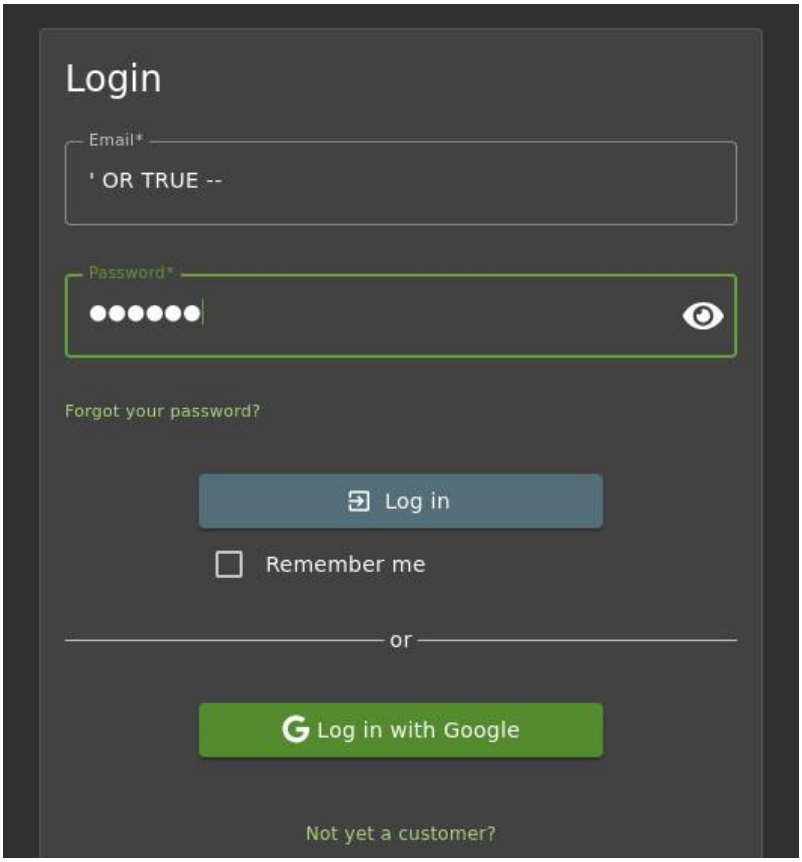
Impact	CVSS Score	Definition
Critical	9.0 – 10.0	Critical vulnerabilities are the highest level of security risks, demanding immediate attention and mitigation within an organization. They pose an imminent and severe threat, with the potential for unauthorized access, data breaches, or significant system compromise. Swift remediation is crucial to maintain robust security.
High	7.0 – 8.9	High severity vulnerabilities should be considered a top priority in terms of mitigation. These are the most severe issues and generally cause an immediate security concern to the enterprise
Medium	4.0 – 6.9	Medium severity vulnerabilities are a lower priority but should still be remediated in a timely manner. These are moderate exploits that

		have less of an impact on the environment.
Low	0.1 – 3.9	Low severity vulnerabilities are real but trivially impactful to the environment. These should only be remediated after the HIGH and MEDIUM vulnerabilities are resolved.
Informational	0.0	Informational vulnerabilities have no impact as such to the environment by themselves. However, they might provide an attacker with information to exploit other vulnerabilities.

The following control areas are the easiest to exploit or expose the environment to the highest level of risk:

Sr. No.	Vulnerability Name	Severity Level
1	SQL Injection	**High**
2	Reflected XSS	**Medium**
3	Remote Code Execution(Not Exploitable)	**Medium**

Sr.No. 1	**Name of Vulnerability:** SQL Injection	**CWE Details:** CWE-89
High	**CVSS Score:** 7.5	
Vulnerable URL: OWASP juice shop		
Description: Improper input sanitization allows attackers to manipulate SQL queries and bypass authentication.		
Impact: Unauthorized access, data leakage, database compromise.		
PoC: 		



Recommendation:

- Use prepared statements, parameterized queries, input validation.

Reference: https://owasp.org/www-community/attacks/SQL_Injection

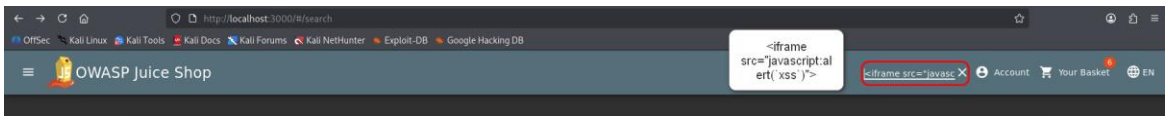
Sr.No. 2	**Name of Vulnerability:** Reflected XSS	**CWE Details:** CWE-79
Medium	**CVSS Score:** 6.1	

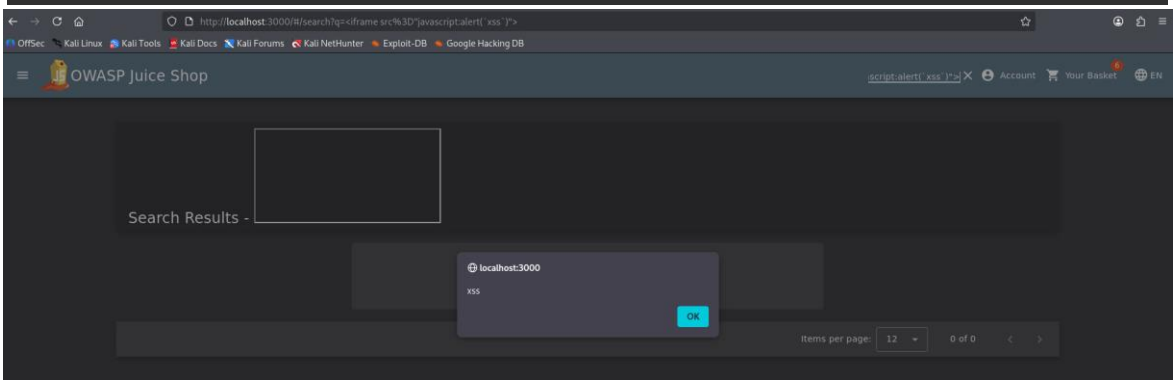
Vulnerable URL: OWASP juice shop

Description: User session theft, redirection to malicious sites.

Impact: Unauthorized access, data leakage, database compromise.

PoC:





Recommendation:

- Input validation, output encoding, use security headers (CSP, X-XSS-Protection).

Reference: https://owasp.org/www-community/attacks/xss/

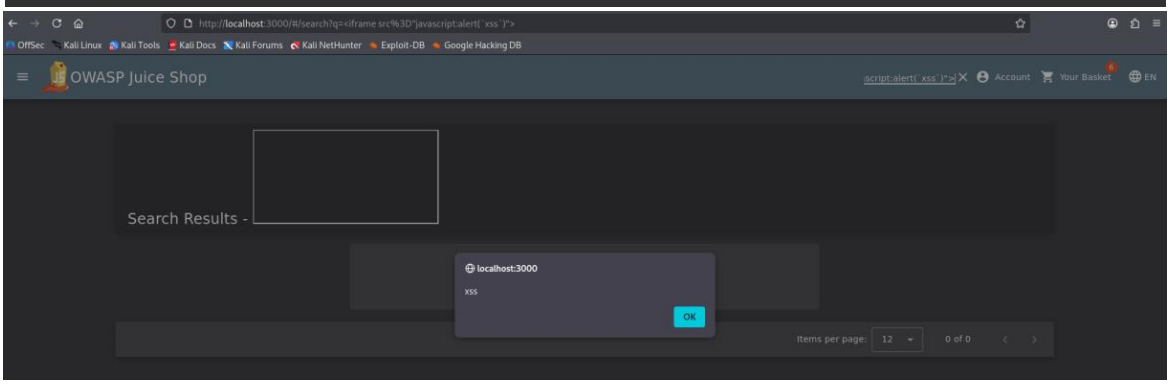
Sr.No. 3	**Name of Vulnerability:** Remote Code Execution (Not Exploitable)	**CWE Details:** CWE-94
Medium	**CVSS Score:** 5.3	

Vulnerable URL: OWASP juice shop

Description: Potential code execution vulnerability exists, but cannot be fully exploited due to restrictions or mitigations.

Impact: Limited impact currently, but could lead to full system compromise if conditions change.

PoC:



Recommendation:

- Patch vulnerable components, validate inputs, restrict execution functions.

Reference: https://owasp.org/www-community/attacks/Code_Injection